Cyber Security Task 2: Phishing Detection & Awareness Report

Intern Name: Leah Padhadu

Task Name: Phishing Email Analysis and Employee Awareness

Date: February 2026

1. Executive Summary

The aim of this task is to analyse common phishing techniques used by cybercriminals to steal credentials and compromise organisational security. This report examines three distinct phishing samples, finds their "red flags," and provides actionable security tips for employees.

Phishing sample analysis

Sample 1: The "Urgent Account Lockdown" (Classic Phishing)

This sample mimics a high-pressure situation to force a quick, unthinking click.

Subject: URGENT: Your Account Has Been Flagged for Suspicious Activity!

From: Amazon Security Team `<support@verify-amazon-security.net>`

Body:

Dear Valued Customer,

We noticed a login attempt from a new device in Moscow, Russia. To protect your account, we have temporarily restricted access to your Prime features and stored payment methods.

To restore access, you must verify your identity immediately by clicking the button below:

[Verify My Account Now]

Failure to verify within 24 hours will lead to permanent account suspension.

Thank you, The Amazon Security Department

Sample 1: Brand Impersonation (Amazon Security)

Subject: URGENT: Your Account Has Been Flagged!

Sender: support@verify-amazon-security.net

The Hook: Uses fear and urgency by claiming an unauthorised login occurred in Moscow, Russia.

Red Flags Identified:

- **Mismatched Domain:** The sender uses .net and a long, unofficial domain instead of the official `amazon.com`
- **Panic Tactics:** The email threatens account suspension within 24 hours to force a fast, unthinking click.

Safety Recommendations

- **Stop:** Do not click any links.
- **Check:** Hover over buttons to see the real destination.
- **Go Direct:** Instead of clicking the email, open a new browser tab and type `amazon.com` yourself.

Technical Note: Because this is a training sample, no technical SMTP headers were available for analysis. In a live environment, I would use an analyser tool to verify the **SPF** and **DKIM** records to confirm the sender's identity.

Sample 2: The "Internal HR Policy" (Business Email Compromise)

Subject: IMPORTANT: Updated Employee Healthcare Benefits for 2026

From: HR Department `<human.resources@yourcompany-portal.com>`

Body:

Hi Team,

Please find the attached document regarding the mandatory updates to our employee healthcare and 401k contribution policies effective next month.

All employees are required to review the new policy and sign the acknowledgment form via the portal link below by Friday EOD.

Link: `http://sharepoint-docs-internal.xyz/auth/login`

Regards,

Sarah Jenkins *HR Benefits Coordinator*

Sample 2: The "Internal HR" Scam

The Scenario: An email that looks like it's from your company's Human Resources department about your benefits.

Subject: IMPORTANT: Updated Employee Healthcare Benefits for 2026

Sender: `human.resources@yourcompany-portal.com`

The Hook: Tells you that you MUST sign a form by Friday or lose your benefits.

Why is this suspicious? (Analysis)

- **Sense of Urgency:** It sets a hard deadline ("Friday EOD") to make you rush.

- **Suspicious Link:** The link goes to. xyz instead of your company's real website (e.g., `.com`).
- **The "From" Name:** It uses a generic "HR Department" instead of a specific person you know in the office.

Header Analysis Status

Note: For this specific investigation, no technical SMTP headers were available. In a real-world incident, I would use an analyser tool to check the **SPF (Sender Policy Framework)** to see if the email originated from our company's authorised mail server. Without headers, I am relying on **Visual Content Analysis**.

Sample 3: The "IT Helpdesk Upgrade" (Technical Phishing)

This sample uses technical jargon to trick users into giving up their network credentials.

Subject: Microsoft 365: Migration to New Secure Server Required

From: IT Support `<admin@mircosoft-365-upgrade.com>`

Body:

Hello User,

Our records show that your mailbox is still running on the legacy server. To prevent data loss and ensure continued sync with Outlook, you must migrate your account to the new **Encrypted Azure Server**.

Please log in to the migration tool here: **[ms-office-migration.com/login]**

Note: Do not close your browser during the migration process.

Systems Administration Team

Sample 3: Technical Social Engineering (IT Helpdesk)

Subject: Microsoft 365: Migration to New Secure Server Required

Sender: `admin@mircosoft-365-upgrade.com`

The Hook: Claims the user must "migrate" their mailbox to prevent data loss.

Red Flags Identified:

- **Typo-Squatting:** The domain is misspelled as "**mircosoft**" (with an extra 'r') to trick the eye.

- **Technical Jargon:** Uses confusing terms like "Legacy Server" to appear authoritative.

Technical Note: Technical headers were not available for this sample. If provided, I would analyse the **Received**fields to identify the "hops" the email took and find the true originating server.

3. Employee Security Awareness Guide

The "Do" List

- **Hover Before You Click:** Always hover your mouse over a link to see the actual web address in the bottom corner of your screen.
- **Verify Through Other Channels:** If you get an urgent HR or IT email, call that department directly using a known number.
- **Report Suspicious Emails:** Use the official "Report Phish" button in your email client at once.

The "Don't" List

- **Don't Trust the "Display Name":** Just because it says "Amazon" or "IT Support" doesn't mean the email address behind it is real.
- **Don't Rush:** Cybercriminals rely on urgency. Take 30 seconds to look for typos or strange domains.
- **Don't Enter Credentials on External Links:** Never type your password into a site reached via an unexpected email link.

4. Conclusion

- By performing visual and technical analysis, we can find phishing attempts before they lead to a data breach. Vigilance and education are our best defences against social engineering.